COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.5 · Hardening Techniques

Mestre CyberSec · **Lesson 2.5 — Hardening Techniques** (12:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Hardening = reduzir superfície de ataque ao mínimo: fechar portas desnecessárias, remover serviço/software (bloatware), trocar senha default, desabilitar conta não usada, patch, MFA, app allowlist, disable USB autorun, BIOS/UEFI password, disable USB boot.

💡 Key Exam Highlights & Critical Concepts

- Surface de ataque = tudo que podes ser atacado — MINIMIZE
- CIS benchmarks = o checklist de hardening por plataforma (padrão da indústria)
- NÃO usar a conta default; desabilitar porta/serviço não usado

🎯 Exam Tips & Typical CompTIA Scenarios

- 'reduces the attack surface of a system' = hardening
- 'checklist of security configuration per platform' = CIS benchmark

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.5 — Hardening Techniques)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Hardening (N/A)

The process of reducing a system's attack surface by applying secure configurations, removing unnecessary components, and enforcing strict security policies.

⚠️ ***Exam Trap:*** *Any answer that 'reduces the attack surface of a system' or 'secures a default configuration' = hardening. Watch for this keyword on SY0-701 Objective 1.3.*

• Attack Surface (N/A)

The sum of all points (ports, services, code, users, interfaces) where an unauthorized user can attempt to enter or extract data from a system.

⚠️ ***Exam Trap:*** *If the question asks 'what is being minimized?', the answer is the attack surface. Hardening = minimizing the attack surface.*

• CIS Benchmarks

Industry-standard, consensus-based checklists for secure configuration of technologies, developed by the Center for Internet Security; used as a baseline for hardening.

⚠️ ***Exam Trap:*** *Trigger phrase: 'industry-recognized checklist of security configuration per platform' or 'configuration baseline' = CIS Benchmarks. Don't confuse with NIST frameworks — CIS is the configuration guide.*

• Default Credentials / Default Account (N/A)

Preconfigured usernames and passwords shipped with a system (e.g., admin/admin, root). Must be changed or disabled during hardening because they are publicly known.

⚠️ ***Exam Trap:*** *Any question showing a known vendor default login being exploited = hardening failure. Both default credentials AND default accounts must be removed/renamed.*

• Bloatware (N/A)

Unnecessary pre-installed software shipped with a device that increases the attack surface and should be removed during hardening.

⚠️ ***Exam Trap:*** *If a question asks 'what should be uninstalled to reduce the attack surface on a new laptop?' = Bloatware. Less software = smaller attack surface.*

• Application Allow List (Whitelist) (N/A)

A hardening control that permits ONLY approved applications to run on a system, blocking everything else by default — the inverse of a block list/blacklist.

⚠️ ***Exam Trap:*** *Allow list = deny by default (more secure). Block list = allow by default (weaker). On exams, prefer allow list for high-security environments. Distinguish from block list.*

• Patching (N/A)

The process of applying vendor updates to fix vulnerabilities, bugs, or improve functionality; a core hardening activity to remediate known exploits.

⚠️ ***Exam Trap:*** *Question showing an unpatched CVE being exploited = patch management failure. Patching is mandatory hardening; pair with firmware/OS updates for full coverage.*

• USB Autorun (Disable) (N/A)

A Windows/host feature that automatically executes software on a connected USB device. Disabling autorun is a hardening control to prevent malicious code execution from removable media.

⚠️ ***Exam Trap:*** *Scenario: 'malware spreads by inserting a USB drive' = USB autorun was enabled. Also disable boot from USB in BIOS/UEFI to complete the hardening.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Full Disk Encryption (FDE / BitLocker) & TPM

🏠 **Real-World Analogy:** If you leave a company laptop in a taxi, a thief does not need your Windows password: they can unscrew the storage drive, mount it as an external drive on another PC, and view every confidential spreadsheet. Full Disk Encryption (BitLocker) renders every stored bit into unintelligible ciphertext. The hardware-backed TPM chip acts as a motherboard safe storing the decryption keys, unlocking only if system boot integrity is confirmed.

🔍 **Root Cause & Background:** Operating system permissions only safeguard data while the OS kernel is executing. Powered-off devices hold data at rest vulnerable to physical drive extraction. Full Disk Encryption ensures data remains unreadable without valid cryptographic authentication.

🛡️ **GRC Auditor Perspective:** Audit enterprise laptop fleets verifying 100% compliance with Full Disk Encryption policies enforced via Intune/MDM; ensure recovery keys are escrowed securely within Active Directory or Microsoft Entra ID.

⚠️ **How CompTIA Tests This:** Trigger: 'a corporate laptop is lost or stolen; what security technology prevents an attacker from extracting the storage drive and accessing sensitive data at rest?'. Answer: Full Disk Encryption (FDE / BitLocker) with TPM.

📌 LAPS (Local Administrator Password Solution)

🏠 **Real-World Analogy:** In a 500-unit condominium, imagine building management keyed every apartment's utility door with identical master cylinders so maintenance staff carry only one key. If an intruder steals the key to unit 101, they can unlock all 500 units! LAPS installs dynamic smart locks on every door, generating randomized, unique, rotating passwords for each apartment, securely escrowed within a central administrative vault.

🔍 **Root Cause & Background:** IT administrators historically configured identical local administrator passwords across workstation fleets. Attackers harvesting local password hashes from one compromised endpoint leveraged Pass-the-Hash techniques to pivot across the entire domain.

🛡️ **GRC Auditor Perspective:** Audit domain-joined endpoints to verify active Windows LAPS enforcement; confirm that local administrator passwords are unique, rotating automatically every 30 days, with access permissions restricted via RBAC.

⚠️ **How CompTIA Tests This:** Trigger: 'tool that prevents lateral movement and Pass-the-Hash attacks by automatically randomizing and managing unique local administrator passwords across domain-joined computers'. Answer: LAPS (Local Administrator Password Solution).

📌 Digital Code Signing & Software Integrity

🏠 **Real-World Analogy:** It is like a tamper-evident holographic safety seal over a medicine bottle cap. You verify the manufacturer's trademark is authentic and that the seal is pristine. If torn, you reject the medicine fearing contamination. Code signing uses public-key cryptography to verify developer identity and prove software code has not been tampered with since release.

🔍 **Root Cause & Background:** Software supply chain compromises inject backdoors directly into third-party software releases and patches. Absent cryptographic signature validation, operating systems execute tampered binaries without warning.

🛡️ **GRC Auditor Perspective:** Mandate through DevSecOps governance that all internal software builds, scripts, and device drivers are cryptographically signed using certificates from trusted CAs, with signing private keys secured within Hardware Security Modules (HSMs).

⚠️ **How CompTIA Tests This:** Trigger: 'cryptographic method used to confirm the identity of the software publisher and ensure application code has not been altered in transit'. Answer: Code Signing.

📌 Application Allowlisting (AppLocker & WDAC)

🏠 **Real-World Analogy:** It is an exclusive VIP guest list at an elite gala. In an open-door party (denylist / legacy AV model), anyone walks in unless their picture is posted on the bouncer's banned troublemaker wall. In a strict VIP event (allowlisting), nobody is admitted unless their verified name appears on the pre-approved registry. If a hacker crafts brand-new zero-day malware, it cannot execute simply because it is not on the VIP list.

🔍 **Root Cause & Background:** Zero-day malware strains possess no known signatures and bypass traditional reactive denylists. Application allowlisting shifts the security paradigm to Zero Trust execution, denying all binaries by default and launching only pre-approved, digitally signed executables.

🛡️ **GRC Auditor Perspective:** Audit Application Control policies (WDAC or AppLocker) across high-risk endpoints and server fleets; verify rules are tied to trusted publisher certificates and cryptographic hashes rather than writable directory paths.

⚠️ **How CompTIA Tests This:** Trigger: 'most effective defensive technique to prevent unauthorized software, malicious scripts, and unknown zero-day malware from executing on corporate computers'. Answer: Application Allowlisting (AppLocker / WDAC).

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Cryptographic protection of data at rest preventing data theft if laptops are lost or stolen	**Full Disk Encryption (FDE / BitLocker)**
Solution automatically randomizing and managing unique local administrator passwords per domain host	**Local Administrator Password Solution (LAPS)**
Lateral movement technique where adversaries harvest a local password hash to authenticate to peer hosts	**Pass-the-Hash (Lateral Movement)**
Using digital certificates to confirm developer identity and guarantee application software integrity	**Code Signing**
Security control that blocks all executable software except binaries explicitly pre-approved	**Application Allowlisting (AppLocker / WDAC)**
Hardware security module on the motherboard storing encryption keys and attesting boot integrity	**TPM (Trusted Platform Module)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A company is preparing a hardened Windows 11 image for its finance department. The current image includes games, trial software, and vendor utilities that finance employees do not use. The security team wants to reduce the attack surface before deployment. Which hardening action should the team take?

A) Enable AutoRun for removable media so users can install needed tools.

B) Give finance users local administrator rights to manage the extra software.

C) Remove unnecessary preinstalled applications and services from the image.

D) Disable the Windows firewall on the image to prevent application conflicts.

QUESTION 2 · EXAM SCENARIO

A technician installs a new network multifunction printer on the corporate LAN. During a security review, the printer web console is still reachable with the vendor's default administrative credentials. Which hardening step is most appropriate?

A) Move the printer to a guest wireless network and keep the default credentials.

B) Change the default administrative credentials and disable unused management accounts.

C) Disable HTTPS management and use Telnet for administrative access.

D) Enable SNMPv1 with the public community string for easier monitoring.

QUESTION 3 · EXAM SCENARIO

A security analyst reviews a legacy file server and finds that the built-in Guest account is enabled, the built-in Administrator account still uses its original name, and an account for a departed administrator remains active. Which hardening action best addresses these findings?

A) Set all affected accounts to use passwords that never expire.

B) Add the accounts to a privileged monitoring group for auditing.

C) Enable remote desktop access for the accounts to simplify administration.

D) Disable or rename unnecessary default accounts and disable inactive accounts.

QUESTION 4 · EXAM SCENARIO

A vulnerability scan finds a critical CVE on a public web server because a required operating system patch was never applied. Which hardening technique directly addresses this finding?

A) Apply the missing operating system and application patches.

B) Implement an application allow list on the web server.

C) Disable USB AutoRun on administrator workstations.

D) Configure a BIOS/UEFI password on the server.

QUESTION 5 · EXAM SCENARIO

A user downloads a malicious executable from the internet and runs it on a managed workstation, infecting the system. The security team wants to prevent unapproved executables from running even when they are downloaded. Which hardening action should be implemented?

A) Disable USB AutoRun on all endpoints.

B) Require users to run as local administrators.

C) Configure an application allow list that permits only approved executables.

D) Move the user's Downloads folder to a mapped network drive.

QUESTION 6 · EXAM SCENARIO

A contractor connects a USB drive to a corporate workstation. Malware on the drive executes automatically because Windows processes an autorun.inf file. Which hardening action should be applied to prevent this behavior?

A) Enable BitLocker To Go for all USB devices.

B) Configure MFA for all user logins.

C) Install an application allow list only on servers.

D) Disable AutoRun/AutoPlay for removable media through Group Policy.

QUESTION 7 · EXAM SCENARIO

A company is concerned about laptop theft and attackers who may have brief physical access. They want to prevent someone from booting from an external USB drive and bypassing operating system controls. Which hardening action is most effective?

A) Set a BIOS/UEFI password and disable booting from external devices.

B) Enable AutoRun for USB devices and require complex passwords.

C) Install an application allow list on the operating system.

D) Apply the latest operating system patches and enable MFA.

QUESTION 8 · EXAM SCENARIO

The company VPN portal authenticates users only with a username and password. After a credential-stuffing campaign, several valid accounts were accessed. Which hardening action best mitigates this risk?

A) Disable unused VPN accounts and patch the VPN appliance.

B) Enforce multifactor authentication for VPN access.

C) Implement an application allow list on VPN clients.

D) Configure BIOS/UEFI passwords on remote laptops.

QUESTION 9 · EXAM SCENARIO

An internal Linux server runs FTP, Telnet, and SMB, but none of these services is necessary for the server's function. Which hardening action best reduces the attack surface?

A) Install a host-based firewall and leave the services running.

B) Enable MFA for local logins and keep FTP/Telnet active.

C) Stop and disable unnecessary services, then close their associated ports.

D) Move the server to a different VLAN without changing services.

QUESTION 10 · EXAM SCENARIO

An organization wants to standardize secure configurations for its Windows servers and needs a recognized set of hardening benchmarks. Which resource should be used as the baseline?

A) CIS Benchmarks.

B) OWASP Top 10.

C) NIST SP 800-63.

D) PCI DSS.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Remove unnecessary preinstalled applications and services from the image.
Removing bloatware and unnecessary applications/services reduces the attack surface by eliminating code that could contain vulnerabilities or be abused. Enabling AutoRun, granting local admin rights, and disabling the firewall all increase risk rather than harden the system.

Question 2: Option B — Change the default administrative credentials and disable unused management accounts.
Default credentials are a well-known weakness and must be changed before placing a device into production. Disabling unused management accounts also reduces the attack surface. Keeping defaults, using Telnet, or enabling SNMPv1 public increases exposure.

Question 3: Option D — Disable or rename unnecessary default accounts and disable inactive accounts.
Default and inactive accounts are common entry points. The server should have unnecessary default accounts disabled or renamed and inactive accounts disabled or removed. Password-never-expires, added privileges, and remote access increase risk.

Question 4: Option A — Apply the missing operating system and application patches.
Patching remediates known vulnerabilities in operating systems and applications and is a core hardening technique. Allow listing, USB AutoRun, and BIOS passwords are useful controls but do not directly fix the missing patch.

Question 5: Option C — Configure an application allow list that permits only approved executables.
An application allow list prevents unauthorized or malicious executables from running, even if they are downloaded. Disabling AutoRun helps with removable media but not downloads. Local admin rights increase risk; moving Downloads does not prevent execution.

Question 6: Option D — Disable AutoRun/AutoPlay for removable media through Group Policy.
Disabling AutoRun/AutoPlay prevents malicious autorun.inf files on USB drives from executing automatically. BitLocker protects data at rest, MFA protects authentication, and allowlisting only servers does not stop autorun on workstations.

Question 7: Option A — Set a BIOS/UEFI password and disable booting from external devices.
A BIOS/UEFI password and disabling external boot options prevent an attacker with physical access from changing boot order or booting another OS from removable media. OS-level controls can be bypassed if the attacker boots externally.

Question 8: Option B — Enforce multifactor authentication for VPN access.
MFA adds a second factor beyond a compromised password, directly mitigating credential stuffing and password reuse. The other actions are hardening measures but do not address single-factor authentication.

Question 9: Option C — Stop and disable unnecessary services, then close their associated ports.
The strongest hardening action is to remove or disable unnecessary services and close the ports they use, reducing the attack surface. A firewall, MFA, or VLAN segmentation can help but do not eliminate the vulnerable services.

Question 10: Option A — CIS Benchmarks.
CIS Benchmarks provide consensus-based secure configuration guidelines for operating systems, servers, and applications. OWASP Top 10 addresses web application risks, NIST SP 800-63 covers digital identity, and PCI DSS is a payment card industry standard.